When the Risk System Becomes the Risk: Design Principles for Assurance Integrity in Governance, Risk and Compliance Information Systems

Name of the Track: Track 1 – Information Systems: Theory and Practice (Digital Ethics and Policy: Regulation and Compliance)

Type of Submission: Ongoing research (design science research; artifact and technical evaluation completed, naturalistic evaluation pending)

Abstract

1. Purpose

Boards, auditors and regulators rely on governance, risk and compliance (GRC) information systems for evidence that risks are identified, rated, approved and controlled. Research on these systems has examined their adoption and value. It has not asked whether the evidence they present can itself be trusted. A forensic audit of a deployed risk management system found that the software invented risk ratings, discarded approvals, accepted unauthenticated authority and reported failed database writes as successes. This study asks which design failures compromise the integrity of assurance evidence. It then asks which design principles prevent them, and how well an instantiation of those principles performs against the original system.

2. Design/Methodology/Approach

The study follows design science research. A code and runtime audit of the deployed system produced a taxonomy of seven failure modes. Each failure mode was matched to a design principle grounded in established theory: fail-safe defaults, complete mediation, separation of duties, tamper-evident logging and the critique of ritualised assurance. The principles were instantiated in a new system, ERMA-GRC. The evaluation compared the original system with ERMA-GRC in 23 scenarios that were pre-registered before execution and run once each against identical stored data. Eighteen scenarios came from the audited failures, four tested the principles beyond them, and one was expected to fail.

3. Findings

The original system prevented the failure in 4 of the 18 audit-derived scenarios. ERMA-GRC prevented it in all 18. Each outcome was read from the stored data, not from what the system reported. It accepted no unauthenticated writes, rejected self-approval, recorded audit entries only under the signed-in identity, detected an edited audit entry, and returned errors instead of false successes. In the generalisation scenarios, ERMA-GRC prevented 3 of 4 failures and the original system none. Two failures of the new design are reported with equal weight. First, a key risk indicator's status was computed correctly in the user interface but could be declared by a client calling the server directly. Second, an insider holding the audit key could rewrite the evidence trail undetected after a restart. The results also show that the principles depend on one another. Separation of duties relies on the integrity of the audit trail, and a principle enforced only in the client offers no assurance.

This Abstract is submitted to LEAD-2027 conference conducted at IIM Shillong during 20-22 January 2027

4. Originality/Value

The study treats assurance integrity as a design property of GRC information systems rather than an organisational outcome. It contributes a failure taxonomy derived from a real system, seven design principles that form a nascent design theory, and a reusable, pre-registered scenario protocol. Practitioners and auditors can use the principles as a procurement and review checklist. The documented boundaries point to future work: externally anchored audit trails, server-side computation of every assurance metric, and evaluation with practitioners.

Keywords

assurance integrity; governance, risk and compliance; design science research; enterprise risk management; audit trail; segregation of duties